

از آنجا که بک‌اند در حال حاضر روی محیط توسعه (Localhost) اجرا می‌شود و دسترسی مستقیم به آن وجود ندارد، لطفاً برای توسعه‌ی فرانت‌اند از داده‌های ساختگی (Mock Data) استفاده کنید. اما بسیار مهم است که ساختار JSON، نام فیلدها و قوانین دسترسی (RBAC) دقیقاً مطابق این داکيومنت پیاده‌سازی شود تا هنگام اتصال نهایی به سرور، هیچ مشکلی پیش نیاید.

سه تا کاربر تستی داریم در سیستم

Manager ->pass:123456

Usertest->pass:123456

Admin->pass:123456

بیشترین دسترسی رو ادمین داره به تمام اکشن‌ها برای تمام کاربران و دیدن لیست trashed همه تسک‌ها

بعد منیجر توان مدیریت تسک‌های خودش و تسک‌های یوزر را دارد و قابلیت تعریف تسک و ربط دادن تسک‌ها به یوزر assignee_id و دلیت کردن و بازگرداندن تسک‌های خودش و یوزر و دیدن لیست تسک‌های پاک شده trashed فقط تسک‌هایی که خودش پاک کرده

و دسترسی‌های یوزر فقط به دیدن تسک‌ها و تغییر استاتوس

نکات استاتوس:

یوزر فقط میتواند از مسیر todo->doing->review->done پیش برود که پایین‌تر هم مسیر دوباره ذکر شده

اما منیجر و ادمین میتوانند هر استاتوسی که خواستند را به یک تسک بدهند

- Base URL (در محیط نهایی): <https://your-domain.com/api>
- فرمت داده: تمام درخواست‌ها و پاسخ‌ها application/json هستند.

۱. احراز هویت (Authentication)

برای تمامی درخواست‌ها (به جز لاگین)، توکن دریافتی باید در هدر درخواست ارسال شود.

درخواست لاگین:

Method: POST •

Endpoint: /auth/login •

• Body: json

```
{ "username": "admin", "password": "123456" }
```

پاسخ موفق:

```
{
  "success": true,
  "data": {
    "user": { "id": 1, "username": "admin", "role": "admin" },
    "token": "aB3xY9" ... (رشته ۶۴ کاراکتری)
  }
}
```

نحوه ارسال توکن در هدر تمام درخواست‌های بعدی:

Authorization: Bearer<توکن_دریافتی>

به تگ authorization برین و bearer token رو انتخاب کنین و توکنی که postman داده بهتون بدون کوتیشن وارد کادر روبرو کنین

۲. لیست کامل API های تسک و قوانین دسترسی (RBAC)

ردیف	عملیات	Method	Endpoint	دسترسی مجاز	توضیحات مهم
------	--------	--------	----------	-------------	-------------

۱	دریافت لیست تسک‌ها	GET	tasks/	همه	Admin: همه Manager: خودش + User: فقط خودش
۲	ساخت تسک جدید	POST	tasks/	Admin, Manager	Body: title, priority, assignee_id
۳	ویرایش تسک	PUT	tasks/{id}/	همه (با محدودیت)	User: فقط status (todo→doing→review→done)
۴	حذف تسک	DELETE	tasks/{id}/	Admin, Manager	Soft Delete
۵	لیست تسک‌های حذف‌شده	GET	tasks/trashed/	Admin, Manager	Manager: فقط trash خودش
۶	بازیابی تسک	POST	tasks/{id}/restore/	Admin, Manager	Manager: فقط تسک‌های حذف‌شده توسط خودش
۷	دریافت زیرتسک‌ها	GET	tasks/{id}/subtasks/	همه	برای چک‌لیست تودرتو

ادامه api ها در اخر فایل

۳. ساختار داده‌ی تسک (Task Object Structure)

هنگام دریافت لیست یا جزئیات تسک، آبجکت تسک شامل فیلدهای زیر است:

Json:

```

}
" id": 12,
" title": "عنوان تسک",
" status": "doing",
" priority": "high",
" assignee_id": 2,
" created_by": 1,

```

```

" deleted_at": null,
" deleted_by": null,
" assignee": { "id": 2, "username": "testuser", "role": "user" },
" createdBy": { "id": 1, "username": "admin", "role": "admin" },
" deletedBy": null,
" subTasks [ ... ] : "
{

```

نکته:

- اگر `deleted_at` مقدار داشت، آیکون سطل زباله یا برچسب "حذف شده" نمایش داده شود.
- نام کاربر حذف‌کننده از `deletedBy.username` قابل خواندن است.

راهنمای نمایش دکمه‌ها در UI بر اساس نقش کاربر

- دکمه "ساخت تسک جدید": فقط برای `Admin` و `Manager` نمایش داده شود.
- دکمه "ویرایش کامل تسک": فقط برای `Admin` و `Manager` نمایش داده شود.
- دکمه "تغییر وضعیت: (Status)" برای همه نمایش داده شود (اما کاربر عادی فقط می‌تواند به ترتیب `done -> review -> doing -> todo`: تغییر دهد).
- دکمه "حذف تسک": فقط برای `Admin` و `Manager` نمایش داده شود.
- دکمه "مشاهده سطل زباله (Trash)" و "بازیابی": فقط برای `Admin` و `Manager` نمایش داده شود.

۴. مدیریت خطاها (Error Handling)

لطفاً بر اساس کد وضعیت (Status Code) پاسخ‌های زیر را در UI نمایش دهید:

- **401 Unauthorized:** توکن نامعتبر است یا منقضی شده → کاربر را به صفحه لاگین هدایت کن.
- **403 Forbidden:** کاربر لاگین است، اما اجازه انجام این کار را ندارد (مثلاً یوزر می‌خواهد تسک را حذف کند) → نمایش پیام: "شما دسترسی لازم برای این عملیات را ندارید".
- **404 Not Found:** تسک مورد نظر پیدا نشد (احتمالاً حذف شده است) → نمایش پیام خطای مناسب.
- **422 Unprocessable Entity:** داده‌های ارسالی اشتباه هستند (مثلاً عنوان خالی است) → پیام خطای `errors message` را زیر فیلد مربوطه نمایش بده.

تمام api ها مربوط به لاگین و تسک و ساب تسک و کامنتو تگ و اتچمنت

(Auth) بخش ۱: احراز هویت

- (بدون نیاز به توکن) POST /api/auth/login: ورود به سیستم
- Body: {"username":"...", "password":"..."}
- سپس برداشتن توکن مربوطه و ادامه عملیات ها(بخاطر سیستم احراز هویت و دسترسی ها تمام اکشن های بعدی بر اساس نقش کاربر و این توکن دریافتی در بخش ذکر شده در بالای فایل کار میکند)

(Tasks) بخش ۲: مدیریت تسک‌ها

- (دسترسی: همه) GET /api/tasks: دریافت لیست تسک‌ها
- (دسترسی: همه) GET /api/tasks/{id}: دیدن جزئیات یک تسک
- (دسترسی: Admin, Manager) POST /api/tasks: ساخت تسک جدید
- (دسترسی: همه، کاربر عادی فقط) PUT /api/tasks/{id}: ویرایش تسک
- (دسترسی: Admin, Manager) DELETE /api/tasks/{id}: حذف تسک
- (دسترسی: Admin, Manager) GET /api/tasks/trashed: لیست تسک‌های حذف‌شده

- (دسترسی: Admin, Manager) POST /api/tasks/{id}/restore: بازیابی تسک

(Subtasks) بخش ۳: زیرتسک‌ها

- (دسترسی: همه) GET /api/tasks/{id}/subtasks: دریافت زیرتسک‌های یک تسک

(Comments) بخش ۴: کامنت‌ها

- (دسترسی:) GET /api/tasks/{taskId}/comments: دریافت لیست کامنت‌های یک تسک (همه)
- (دسترسی: همه) GET /api/tasks/{taskId}/comments/{id}: دیدن جزئیات یک کامنت
- (دسترسی: همه با توکن) POST /api/tasks/{taskId}/comments: ساخت کامنت جدید
- (دسترسی: فقط نویسنده کامنت) PUT /api/comments/{id}: ویرایش کامنت
- (دسترسی: Admin) DELETE /api/comments/{id}: حذف کامنت
- (دسترسی: فقط نویسنده یا Admin) PATCH /api/comments/{id}/restore: بازیابی کامنت

(Tags) بخش ۵: تگ‌ها

- (دسترسی: همه) GET /api/tags: دریافت لیست همه تگ‌ها
- (دسترسی: همه) GET /api/tags/{id}: دیدن جزئیات یک تگ
- (دسترسی: Admin, Manager) POST /api/tags: ساخت تگ جدید
- (دسترسی: Admin, Manager) PUT /api/tags/{id}: ویرایش تگ
- (دسترسی: Admin, Manager) DELETE /api/tags/{id}: حذف تگ
- (دسترسی: همه با توکن) POST /api/tasks/{taskId}/tags: سینک تگ‌ها با یک تسک
Body: {"tag_ids": [1, 2, 3]}

(Attachments) بخش ۶: فایل‌های پیوست

- GET /api/tasks/{taskId}/attachments: دریافت لیست فایل‌های یک تسک (دسترسی: همه)
- (دسترسی: همه با توکن) POST /api/tasks/{taskId}/attachments: آپلود فایل جدید
(کلید: file) form-data: فرمت
- (دسترسی: همه) GET /api/attachments/{id}/download: دانلود فایل
- (دسترسی: Admin) DELETE /api/attachments/{id}: حذف فایل

نکات فنی مهم:

- تمام API ها به جز login نیاز به هدر Authorization: Bearer {token} دارند.
- برای آپلود فایل (Attachments) ، فرمت درخواست باید form-data باشد، نه JSON.
- کامنت ها و فایل ها همیشه زیرمجموعه یک تسک هستند (URL به شکل /tasks/{taskId}/comments).
- برای سینک تگ ها، لیست ID تگ ها را در آرایه tag_ids بفرستید.
- کدهای وضعیت: ۲۰۰ موفق، ۲۰۱ ساخته شد، ۴۰۱ توکن نامعتبر، ۴۰۳ دسترسی ممنوع، ۴۰۴ پیدا نشد.
- ساب تسک ها در صورت وجود نمایش داده میشوند و همونجور که صحبت کردیم بصورت چک لیست نمایش داده میشوند
- زمانی که تمام ساب تسک ها تیک بخورند وضعیت ساب تسک ها و تسک اصلی done میشود
- به نحوه لاگین اولیه و نحوه تغییر استاتوس ها حتما دقت کنین

نمونه درخواست ها و پاسخ های آن ها

۱. نمونه درخواست لاگین (Login)

درخواست: (Request)

POST /api/auth/login

Content-Type: application/json

```
}  
" username": "admin,"  
" password": "123456"  
{
```

پاسخ موفق: (Response - 200 OK)

```
{
  "success": true,
  "message": "ورود با موفقیت انجام شد",
  "data": {
    "user": {
      "id": 1,
      "username": "admin",
      "role": "admin"
    },
    "token": "aB3xY9... (رشته ۶۴ کاراکتری توکن)"
  }
}
```

۲. نمونه ساخت تسک جدید توسط Admin یا Manager

درخواست: (Request)

POST /api/tasks

Authorization: Bearer <توکن دریافتی>

Content-Type: application/json

```
{
  "title": "طراحی صفحه اصلی",
  "priority": "high",
  "assignee_id": 2
}
```

پاسخ موفق: (Response - 201 Created)

```
{
  "success": true,
  "data": {
    "id": 25,
    "title": "طراحی صفحه اصلی",
    "status": "todo",
    "priority": "high",
    "assignee_id": 2,
    "created_by": 3,
    "deleted_at": null,
    "deleted_by": null,
    "assignee": { "id": 2, "username": "testuser", "role": "user" },
    "createdBy": { "id": 3, "username": "manager", "role": "manager" },
    "deletedBy": null,
    "subTasks": []
  }
}
```

۳. نمونه تغییر وضعیت تسک (توسط کاربر عادی)

نکته: کاربر عادی فقط مجاز است *status* را ارسال کند و فقط در مسیر مجاز.

درخواست: (Request)

PUT /api/tasks/25

Authorization: Bearer <توکن کاربر عادی>

Content-Type: application/json

```
{
```

```
"status": "doing"
}
```

پاسخ موفق: (Response - 200 OK)

```
{
  "success": true,
  "data": {
    "id": 25,
    "title": "طراحی صفحه اصلی",
    "status": "doing",
    "priority": "high",
    "assignee_id": 2,
    "updated_at": "2026-06-07 15:30:00"
  }
}
```

۴. نمونه خطای دسترسی (Forbidden)

اگر یک کاربر عادی (user) سعی کند تسکی را حذف کند (که مجاز نیست)، سرور این پاسخ را می‌دهد:

درخواست: (Request)

DELETE /api/tasks/25

Authorization: Bearer <توکن_کاربر_عادی>

پاسخ خطا: (Response - 403 Forbidden)

```
{
  "success": false,
  "message": "کاربران عادی اجازه‌ی حذف تسک را ندارند."
}
```

